

STAGE 1

Setting paths:

```
TARGET="/home/user01/ghidra-codeql-analysis/ghidra-10.0.4-  
public/ghidra_10.0.4_PUBLIC"
```

```
R="/home/user01/ghidra-codeql-analysis/reports"
```

```
mkdir -p "$R"
```

Direct bundled jar ground truth

```
find "$TARGET" -name "log4j-core-2.12.1.jar" -print \  
| tee "$R/stage1-ghidra-groundtruth-log4j-core.txt"
```

Syft SBOM tool:

```
syft dir:"$TARGET" \  
-o syft-json="$R/syft-ghidra.json" \  
-o cyclonedx-json="$R/syft-ghidra-cyclonedx.json" \  
-o spdx-json="$R/syft-ghidra-spdx.json"
```

```
jq -r '  
.components[]?  
| select(  
  (.name // "" | test("log4j-core"; "i"))  
  or  
  (.purl // "" | test("log4j-core"; "i"))  
)  
| [.name, .version, .purl]  
| @tsv
```

```
' "$R/syft-ghidra-cyclonedx.json" \  
| tee "$R/stage1-ghidra-syft-log4j-core.tsv"
```

Trivy SBOM tool:

```
trivy fs "$TARGET" \  
  --format cyclonedx \  
  --output "$R/trivy-ghidra-cyclonedx.json"
```

```
jq -r '  
  .components[]?  
  | select(  
    (.name // "" | test("log4j-core"; "i"))  
    or  
    (.purl // "" | test("log4j-core"; "i"))  
    or  
    (."bom-ref" // "" | test("log4j-core"; "i"))  
  )  
  | [.name, .version, .purl, ."bom-ref"]  
  | @tsv  
' "$R/trivy-ghidra-cyclonedx.json" \  
| tee "$R/stage1-ghidra-trivy-log4j-core.tsv"
```

Cdxgen jar analysis:

```
cdxgen -t jar \  
  --deep \  
  --spec-version 1.6 \  

```

```
-o "$R/cdxgen-ghidra-jar-deep-cyclonedx.json" \  
"$TARGET"
```

```
jq -r '  
.components[]?  
| select(  
  (.name // "" | test("log4j-core"; "i"))  
  or  
  (.purl // "" | test("log4j-core"; "i"))  
  or  
  (."bom-ref" // "" | test("log4j-core"; "i"))  
)  
| [.name, .version, .purl, ."bom-ref"]  
| @tsv  
' "$R/cdxgen-ghidra-jar-deep-cyclonedx.json" \  
| tee "$R/stage1-ghidra-cdxgen-log4j-core.tsv"
```

Grype on Syft SBOM tool:

```
grype sbom:"$R/syft-ghidra-cyclonedx.json" \  
-o json > "$R/grype-on-syft-sbom.json"
```

```
grype sbom:"$R/syft-ghidra-cyclonedx.json" \  
-o table | tee "$R/grype-on-syft-sbom.txt"
```

```
jq -r '  
.matches[]?
```

```

| select(
  (.artifact.name // "" | test("log4j-core"; "i"))
  or
  (.artifact.purl // "" | test("log4j-core"; "i"))
)
| [
  .artifact.name,
  .artifact.version,
  .artifact.type,
  .artifact.purl,
  .vulnerability.id,
  .vulnerability.severity
]
| @tsv
' "$R/grype-on-syft-sbom.json" \
| tee "$R/stage1-ghidra-grype-log4j-vulns.tsv"

```

Trivy on Syft SBOM tool:

```

trivy sbom "$R/syft-ghidra-cyclonedx.json" \
  --scanners vuln \
  --format json \
  --output "$R/trivy-on-syft-sbom.json"

```

```

jq -r '
  .Results[]?
  | .Vulnerabilities[]?

```

```
| select(
  (.PkgName // "" | test("log4j-core"; "i"))
  or
  (.PkgIdentifier.PURL // "" | test("log4j-core"; "i"))
)
| [
  .PkgName,
  .InstalledVersion,
  .VulnerabilityID,
  .Severity,
  (.FixedVersion // "")
]
| @tsv
' "$R/trivy-on-syft-sbom.json" \
| tee "$R/stage1-ghidra-trivy-log4j-vulns.tsv"
```